通用 AI Agent 安全风险检测与防御闭环

项目实施计划书 v1.2：AgentRange 靶场适配与协作分工版

基于 DefenseClaw/AgentScan2 主干与 OpsPilot AgentRange 靶场，按场景、模块 owner、接口契约和验收指标并行推进

版本：v1.2 | 日期：2026-07-18 | 建议周期：4 周 MVP / 2 周加固与报告

核心调整：把 v1.1 的“通用多 connector + eBPF POC”收敛为 AgentRange 可评分闭环。DefenseClaw 是检测/决策中心，OpsPilot 与 Langflow 只通过 adapter 接入；规则必须行为泛化，禁止读取轨迹答案或按场景编号硬编码。

1. 修订目标

本版以 task/AgentRange-player 为唯一 MVP 验证靶场，保留 v1.1 的模块化协作框架，但将泛化的 connector、eBPF 和多框架目标收敛为可评分的 OpsPilot 垂直闭环。改造必须同时覆盖资产识别、配置风险、恶意 Skill/MCP、运行时攻击、实时阻断、攻击链证据和量化报告。

- 以 7 类靶场场景为验收主线：C1-A/C1-B、C2-A/C2-B/C2-C/C2-D 和 normal，不以场景编号硬编码检测规则。
- 复用 DefenseClaw 现有 skill/mcp/plugin scanner、CodeGuard、/api/v1/inspect/*、observe/action、audit、OTel 和策略引擎；新增内容优先放 adapter、rules、bench 边界。
- 评分口径前置：资产盘点准确率、风险识别准确率、Precision/Recall/FPR/FNR、p95 阻断延迟、CPU 增量和正常业务成功率必须可重复计算。
- 先完成 OpsPilot Prompt→LLM→Tool→MCP→Tool Result 闭环和 Langflow 入口保护，再抽象为通用 connector；不先铺开其他 Agent。

2. 模块拆分总览

模块	唯一 Owner	主要目录/边界	输入/输出契约	MVP 验收

M0 靶场契约与 Ground Truth	A 架构/数据负责人	schemas/、task/.../contracts、scenario matrix	资产清单、RangeEvent、GroundTruth、Decision、AttackChain	7 类场景与 normal 标签冻结；资产分母和统计口径有测试
M1 静态扫描/资产风险	B 资产扫描负责人	cli/defenseclaw/scanner、inventory、CodeGuard、integration/static_scan.ps1	AssetRecord、Finding、asset_edges、risk taxonomy	7 Skill、8 MCP 和配置均入清单；meeting-summary/notes-sync 风险检出
M2 运行时适配	C Agent 集成负责人	task/AgentRange-player/integration、opspilot-app/security、compose	/api/v1/inspect/*、session_id、403 block contract	四阶段检查和 Langflow 入口代理可禁用/observe/action；单测通过
M3 检测规则	D 检测算法负责人	internal/gateway/rules、guardrail rule packs、fixtures	RuleFinding、severity、confidence、direction	C1/C2 行为规则检出且 normal FPR < 5%；无场景 ID 硬编码
M4 关联/攻击链	E 关联与审计负责人	internal/audit、router/correlator、attack-chain report	RangeEvent→Attack Chain DAG、evidence_level、raw_ref	至少 C2-B/C2-D/C1-A 输出完整可解释链和审计引用
M5 Enforcement/策略	F 策略负责人	policies、inspect decision、network/identity policy	observe/action、scope、fail mode、block reason	高危副作用 action 阻断；observe 0 阻断；合法 threat-intel 不误杀

M6 Benchmark/性能	G 测试性能负责人	test/、task/.../bench、metrics	ground truth join、TP/FP/TN/FN、latency/resource JSON	输出 Precision/Recall/FPR/FNR、p95、CPU、正常成功率三组对照
M7 集成/报告/Demo	H 集成交付负责人	task/.../integration、docs/report、demo scripts	一键命令、报告模板、截图清单、发布检查	从空环境可复现静态扫描、observe、action、攻击链和最终报告

3. 并行开发规则

- 契约先行：M0 在 Week 1 冻结 AgentRangeAsset、RangeEvent、RangeGroundTruth、Decision、AttackChain 的字段和 7 类场景样例；后续模块不得私自改变统计口径。
- 靶场基线保护：DEFENSECLAW_API_BASE 为空时必须保持原靶场行为；observe 模式不得阻断；action 模式只阻断达到策略阈值的副作用动作。
- 分支隔离：task/AgentRange-player/integration 由 M2 owner 维护；internal/gateway 与 policies 由 M3/M5 owner 维护；bench/report 由 M6/M7 owner 维护。
- 证据可追踪：所有检测必须记录 instance_id/trace_id、阶段、资产、规则、原始引用、决策、延迟和降级原因；禁止读取 /admin/trajectories 作为检测证据。
- 每周两次集成：周三合并 observe 基线，周五合并 action 演示；共享契约改动需 M0 reviewer，策略阈值改动需 M6 复测正常流量。

4. 模块任务包

M0 靶场契约与 Ground Truth

- 盘点 OpsPilot、llm-stub、Langflow、PostgreSQL、8 个 MCP、7 个 Skill、2 个网络和 6 个宿主机端口，形成唯一资产清单与关系图。
- 为 C1-A/B、C2-A/B/C/D、normal 定义攻击目标、首个危险动作、允许观察点、成功/阻断判据和 instance 级标签；不得使用轨迹管理接口内容作为检测输入。
- 输出契约样例、场景矩阵和统计口径测试，供扫描、检测、关联和 benchmark 共用。

输出：assets.yaml、scenario-matrix.yaml、ground-truth.schema.json、7 类攻击与 normal 示例事件、统计口径说明。

M1 静态扫描与资产风险识别

- 用现有 skill scan 和 CodeGuard 扫描 7 个 Skill、8 个 MCP 源码、docker-compose、.env.example 与 Langflow 镜像定义，输出统一 Finding。
- 新增靶场风险 taxonomy：隐藏提示指令、tools/list 与 tools/call 不一致、启动信标外联、shell=True、任意文件读取、弱 JWT、服务账号越权传播和明文凭据。
- 实现资产去重和 Agent→Skill/MCP→Tool→Network/Database 关系，逐项与 M0 清单核对漏报和误报。

输出：静态扫描脚本、资产关系图、风险 taxonomy、Finding 导入映射、误报/漏报对照表。

M2 OpsPilot/Langflow 运行时适配

- OpsPilot 在完整 messages、工具调用前、工具结果后和最终响应四阶段调用 /api/v1/inspect/*；X-Instance-Id 作为 session_id 贯穿审计。
- Langflow 通过 langflow-guard 入口代理检查方法、路径、查询串和 JSON/Multipart 内容，真实 Langflow 不再直接暴露宿主机端口。
- 适配器支持禁用、Token 鉴权、250ms 默认超时、fail-open/fail-closed；单测覆盖 allow、block、网关不可用和未配置基线。

输出：OpsPilot 四阶段 inspect client、Langflow ingress guard、Compose 接线、Token/超时/fail-mode 配置和单测。

M3 靶场检测规则

- 实现可泛化的工具参数规则：下载后执行、管道进 shell、定时任务/路径穿越、C2 回连、敏感文件读取、通配租户和跨租户访问。
- 实现静态描述规则：ignore/隐藏/不得告知/先读取凭据等指令组合、隐藏工具、启动外传和高危执行原语；避免把正常 password-policy 文本误判为攻击。

- 每条规则必须有 attack/benign 对照夹具、severity/confidence、observe/action 期望和性能上限；不得匹配固定 scenario ID。

输出：工具参数/描述/身份/网络规则包、attack-benign fixtures、规则性能测试和阈值说明。

M4 关联与攻击链还原

- 按 instance_id/trace_id 关联 Prompt、Skill、LLM tool_call、MCP 调用、文件/数据库访问、网络目标和 Decision，输出 AttackChain DAG。
- 优先实现三条序列：敏感文件读取→同步/外联、外部内容→命令执行、身份 scope→跨租户查询；直接证据与时间窗推断分别标注。
- 报告至少定位污染源、关键工具参数、阻断点、未执行副作用和审计记录引用；C1 链路由 Langflow 请求而非 Agent 工具起始。

输出：instance/trace 关联逻辑、三条 sequence 规则、AttackChain JSON、审计查询和可解释证据报告。

M5 Enforcement 与策略

- observe 建立全量 5200 条基线；action 对 CRITICAL/HIGH 确定性副作用阻断，Prompt 风险可先告警并在工具前兜底。
- 身份越权以 JWT scope、用户 tenant 与工具 tenant 联合判定；网络策略区分合法 threat-intel 出网与 notes-sync/curl 外传。
- 定义超时和故障策略：业务默认 fail-open 留痕，高危演示可 fail-closed；所有降级必须进入审计和指标报告。

输出：observe/action 策略、租户 scope 策略、出网区分策略、阻断响应、降级日志和正常业务回归。

M6 Benchmark 与性能

- 按 instance 而非单 HTTP 请求计算 TP/FP/TN/FN；恶意实例以危险副作用执行前被阻断为 TP，正常实例被阻断为 FP。

- 采集 inspect p50/p95/p99、端到端延迟、DefenseClaw CPU/内存增量、正常流量成功率；固定 seed=1337、total=5200、malicious_target=80。
- 提供 baseline/observe/action 三组可重复命令、原始 JSON 结果、误报/漏报清单和阈值变更记录。

> 输出：baseline/observe/action benchmark、原始指标 JSON、误报漏报清单、p95/CPU/内存/业务成功率报告。

M7 集成、演示与交付报告

- 维护一键启动、静态扫描、逐场景回放、全量 benchmark、告警查询和清理脚本；Windows Docker Desktop 与 Linux 均给出路径。
- 固定 Demo 顺序：资产盘点→恶意 Skill/MCP 准入发现→observe 留证→action 阻断 C2-D→攻击链→指标看板→C1 入口阻断。
- 交付源码、技术说明、检测报告、攻击链证据、指标报告、配置样例和失败降级说明，所有截图可由命令重新生成。

> 输出：Windows/Linux 操作手册、一键联调脚本、固定 Demo、技术说明、检测报告和验收证据索引。

5. 分支、PR 与集成节奏

分支/节奏	允许改动	负责人	合并门槛
main	仅接收通过全量靶场演示的 integration	A + H	静态扫描、normal、C1/C2、指标报告全部可复现
integration	周三 observe、周五 action 汇合	H	Compose/单测/契约测试通过，演示链路无人工补数据

feature/range-contracts	M0 schema、清单、场景矩阵	A	M0 reviewer 通过，口径冻结
adapter/agentrange	OpsPilot/Langflow 适配器和 Compose	C	未配置保持基线；observe/action 契约测试通过
rules/agentrange	检测、关联和策略规则	D/E/F	每条规则 attack+2 benign；无固定场景特征
bench/agentrange	回放、指标、性能与报告	G/H	固定 seed 可重跑；原始结果和汇总一致

PR 必须绑定任务 ID 和场景矩阵行，附测试命令、预期/实际结果、性能变化及失败日志。共享文件修改先经 owner；规则 PR 至少包含一个恶意样本和两个易混淆良性样本；禁止把靶场答案或固定 instance/scenario ID 写入生产规则。

6. 4 周 MVP 并行排期

周期	A/C 契约与适配	B/D 资产与检测	E/F 关联与策略	G/H 验证与交付
Week 1	冻结资产/场景/事件契约；完成四阶段 inspect 与 Langflow guard	跑静态基线；建立恶意/良性规则夹具	定义三条攻击链与 observe/action 阈值	建 benchmark 骨架；保存 baseline 原始结果
Week 2	完善鉴权、超时、fail-mode、Docker/Windows 接线	覆盖 C1-A/B、C2-C/D 确定性规则	审计 join 与 C2-D 链；action 首次阻断	逐场景回放；统计 Recall/FPR/延迟
Week 3	修复集成缺陷，抽象 adapter 契约	覆盖 C2-A/B 身份/序列规则并降误报	完成 C1/C2 三类链、scope/egress	全量 5200 observe/action；

			策略	CPU/内存采样
Week 4	冻结接口与演示镜像	阈值冻结、风险清单定稿	策略回归、证据索引和攻击链报告定稿	验收指标、技术说明、检测报告、Demo 彩排与发布

7. 任务分发模板

字段	填写要求
任务 ID	M 编号-序号；必须绑定一个或多个场景矩阵行，例如 M3-002/C2-C
Owner/Reviewer	唯一 Owner；Reviewer 至少一名来自上游契约或下游验证模块
输入契约	资产/事件 schema、API、场景夹具、DefenseClaw 模式和依赖版本
输出契约	代码目录、规则 ID、审计字段、报告 JSON、CLI/HTTP 示例
完成标准	给出可复制命令、预期结果、单测/集成测试和性能阈值，不能只写“完成”
风险/降级	鉴权、Docker 到宿主机、超时、误杀、外部依赖及 fail-open/closed 选择
禁止事项	不得读取 trajectories 答案、硬编码场景/实例、绕过审计、关闭 API 鉴权或破坏未保护基线

8. 当前应立即派发的首批任务

优先级	任务	Owner 建议	依赖	完成标准
P0	M0-001 冻结资产清单、7 类场景矩阵和 instance 级统计	A	AgentRange 源码/手册	清单、标签和 TP/FP/TN/FN 定义评审通

	口径			过；不使用 trajectories
P0	M2-001 完成 OpsPilot 四阶段 inspect 与 Langflow ingress guard	C	DefenseClaw inspect API	禁用保持基线；observe 放行留证；action 返回 403；单测/Compose 通过
P0	M1-001 跑通 7 Skill/8 MCP/配置静态扫描并导入 Finding	B	M0-001	检出 meeting-summary、notes-sync、弱 JWT/服务账号传播，资产漏报 < 5%
P0	M3-001 实现 C1/C2 确定性副作用规则包和良性对照	D	M0/M1/M2	C1-A/B、C2-C/D 命中；password-policy、正常测试和 threat-intel 不误杀
P1	M4-001 关联敏感文件读取→同步/外联攻击链	E	M0/M2/M3	C2-B/C2-D 输出 DAG、证据级别、Decision、raw_ref 和审计查询
P1	M5-001 租户 scope、出网区分和 observe/action 策略	F	M3/M4	C2-A/B 阻断；合法 ACME 查询与 threat-intel 放行；降级留痕
P1	M6-001 固定 5200 条 baseline/observe/action benchmark 与报告	G/H	全部模块	可复现 Precision/Recall/FPR/FNR、p95 < 1s、CPU≤5%、正常成功率

9. 验收口径

- 资产验收：Agent 相关资产盘点漏报率 < 5%、准确率≥99%；恶意 Skill/MCP 与配置风险识别准确率≥95%、漏报率 < 5%，均以 M0 冻结清单为分母。

- 运行时验收：漏洞利用与 Agent 异常行为 Recall≥95%、FPR < 5%、阻断响应 < 1 秒；正常业务 0 中断目标以 normal 回放成功率和回归结果证明。
- 性能验收：DefenseClaw 增量 CPU≤5%，报告 p50/p95/p99 延迟、内存增量及环境规格；不得只给平均值。
- 证据验收：每条攻击链可定位污染输入、工具调用、文件/数据库/网络副作用、Decision 和阻断结果；所有结论可从审计记录复核。

10. 不做事项

- 不在 MVP 阶段扩展其他 Agent connector；OpsPilot 与 Langflow 闭环通过后再抽象通用 adapter。
- 不把 `/admin/trajectories`、scenario ID、固定 prompt 或固定 instance ID 用作检测特征。
- 不要求 eBPF 作为 MVP 阻断前置条件；优先使用应用 Hook、网关审计和 Docker 网络证据，eBPF 仅作增强证据。
- 不把外部 LLM Judge 放入默认同步阻断路径；确定性本地规则负责 < 1 秒响应，语义复核走异步慢路径。
- 不直接暴露无鉴权的 DefenseClaw inspect API 到局域网；Docker 到宿主机必须使用 API Token 和受限监听/转发。